

Chapter 7 — Privacy Governance, Classification, Purpose, and Data Lifecycle

1. Document control

- Identifier: HAL-BVI-07
- Version: 1.0
- Status: Final
- Effective date: 2026-07-27

2. Purpose

Operationalize dignity, classification, authority, collection and purpose limitation, minimization, retention, deletion, export, and lifecycle evidence.

3. Scope

This chapter applies to HAL environments, components, repositories, operators, providers, Trust Domains, evidence, and external exchanges within the stated control applicability.

4. Authority and source requirements

- Book I: Articles IX-X; Decisions 10, 30, 39-40, 45, 48, 55
- Book II: Chapters 12, 14, 18, 24, 27, 29
- Book III: Chapters 5-6, 8
- Book IV: CMP-08-10, CMP-18-19, CMP-24, CMP-27
- Book X: Chapters 7-8, 10
- Book VIII governs verification and certification decisions; Book IX governs exact machine contracts.

5. Definitions and accountable roles

Book X terms retain their canonical meaning. Chapter roles: Privacy Steward, Data Owner, Purpose Owner, Retention Owner, Privacy Engineer, Independent Assessor.

6. Normative controls

VI-PRV-07-001 — Classify before processing

Data MUST be classified before collection, inference, storage, use, disclosure, replication, or deletion; unknown classification MUST receive the most protective plausible handling.

- Applicability: all data
- Responsible role: Data Owner
- Enforcement: schema and admission validation
- Required evidence: classification record
- Severity: Critical
- Exception authority: None
- Protection objective: Both

VI-PRV-07-002 — Prove purpose and authority

Every personal or sensitive-data operation MUST bind an authorized purpose, applicable Authority or consent basis, permitted processing, recipients, retention, and evidence.

- Applicability: personal and sensitive data
- Responsible role: Purpose Owner
- Enforcement: purpose-policy enforcement
- Required evidence: purpose and authority decision
- Severity: Critical
- Exception authority: None
- Protection objective: Constrain HAL

VI-PRV-07-003 — Collect the minimum

Collection MUST be limited to fields, precision, frequency, population, duration, and sources demonstrably necessary for the authorized purpose; convenience and possible future use are insufficient.

- Applicability: all collection
- Responsible role: Privacy Steward
- Enforcement: collection review and field gate
- Required evidence: minimization assessment
- Severity: Critical
- Exception authority: Privacy Steward
- Protection objective: Both

VI-PRV-07-004 — Prevent incompatible reuse

Data MUST NOT be reused, combined, enriched, modeled, or disclosed for a materially different purpose without a new valid authority and privacy assessment.

- Applicability: secondary use
- Responsible role: Purpose Owner
- Enforcement: purpose binding checks
- Required evidence: reuse decision record
- Severity: Critical
- Exception authority: None
- Protection objective: Constrain HAL

VI-PRV-07-005 — Set enforceable retention

Every data class MUST have an accountable retention rule, trigger, duration, legal or constitutional holds, archive behavior, backup treatment, and verifiable disposal path.

- Applicability: stored data
- Responsible role: Retention Owner
- Enforcement: retention controller
- Required evidence: retention schedule
- Severity: High
- Exception authority: Privacy Steward
- Protection objective: Both

VI-PRV-07-006 — Honor deletion across derived stores

Authorized deletion **MUST** address authoritative records, replicas, caches, indexes, embeddings, models where technically applicable, exports, and backups, while preserving required constitutional and incident accountability.

- Applicability: deletion requests
- Responsible role: Retention Owner
- Enforcement: deletion workflow and verification
- Required evidence: deletion certificate
- Severity: Critical
- Exception authority: Privacy Steward
- Protection objective: Both

VI-PRV-07-007 — Provide confidentiality- and integrity-protected access and export

Access or export **MUST** verify requester identity and Authority, obtain Permission for the exact subject and purpose, preserve provenance and context, use authenticated, confidentiality- and integrity-protected delivery, and prevent disclosure of others' rights or secrets.

- Applicability: access and export
- Responsible role: Data Owner
- Enforcement: request validation
- Required evidence: access/export manifest
- Severity: Critical
- Exception authority: None
- Protection objective: Both

VI-PRV-07-008 — Minimize privacy evidence

Privacy compliance evidence **MUST** prove the decision without unnecessarily reproducing sensitive content; access to evidence **MUST** itself be classified, authorized, logged, and reviewed.

- Applicability: privacy evidence
- Responsible role: Evidence Custodian
- Enforcement: redaction and access controls
- Required evidence: minimized evidence manifest
- Severity: High
- Exception authority: Privacy Steward
- Protection objective: Both

7. Required operating practices

Control Owners **MUST** maintain procedures, training, tools, dependencies, evidence paths, response actions, and succession coverage necessary to operate each applicable control.

8. Prohibited practices

- Treating trust, identity, credentials, compliance, or certification as Authority.
- Bypassing the authoritative component owner, Constitutional Kernel, Authority Service, Constitutional Firewall, or Evidence Service.

- Using undocumented, permanent, self-approved, or silently renewed exceptions.
- Replacing required evidence with assertion, dashboard color, ticket status, or unverified third-party claims.

9. Required evidence

Evidence MUST identify the control, target, version, environment, actor, time and confidence, source, method, outcome, exceptions, integrity, classification, retention, and linked incident or remediation.

10. Automated enforcement

Controls marked automated MUST deny, quarantine, expire, alert, or constrain according to the stated failure behavior. Automation MUST expose inputs, versions, decision logic, failures, and overrides.

11. Human review

A qualified reviewer MUST evaluate proportionality, constitutional restraint, privacy, trust assumptions, evidence sufficiency, conflicts of interest, and residual risk at the control's declared cadence and after material change.

12. Exceptions and failure consequences

Constitutional invariants are not waivable. Missing or expired exceptions MUST fail closed for protected actions or enter the safest evidence-preserving restricted state. Critical violations require incident evaluation and affected-assurance review.

13. Security, privacy, trust, and reliability considerations

Implementations MUST minimize sensitive evidence, preserve recoverability, constrain compromised components, keep trust separate from permission, and maintain auditable denial and recovery paths.

14. Verification method and metrics

Verify by catalog completeness checks, policy and configuration tests, adversarial negative cases, sampled evidence reconstruction, incident and recovery exercises, and independent review. Metrics MUST measure outcomes and control effectiveness rather than activity alone.

15. Traceability

- Book I: Articles IX-X; Decisions 10, 30, 39-40, 45, 48, 55
- Book II: Chapters 12, 14, 18, 24, 27, 29
- Book III: Chapters 5-6, 8
- Book IV: CMP-08-10, CMP-18-19, CMP-24, CMP-27
- Book X: Chapters 7-8, 10

16. Examples and anti-patterns

Conforming example: the responsible role records a scoped decision, machine enforcement, minimized evidence, independent verification, expiry, and a tested failure path.

Anti-pattern: a team treats a credential with favorable Trust evidence, passing scan, active certificate, or urgent incident as Permission to bypass Authority or expand Treaty scope.

17. Review findings, Owner Review, and completion

Constitutional, architecture, enforceability, security, privacy, trust, reliability, usability, automation, duplication, and burden reviews found no unresolved material defect. No Owner Review item is required. Status: Complete.